

Normativas de Seguridad de Información y Estándares Externos

Banco Ther S.A



UNIVERSIDAD
CATÓLICA
BOLIVIANA

Carrera: Ingeniería de Sistemas

Materia: Auditoria de Sistemas

Semestre: 9no Semestre

Integrantes:

García Aguirre Ignacio

Mattos Terán Fernanda

Pimentel Silva Jared

Quenta Ramos Ramiro

Valenzuela Rivera Mateo

Fecha: 3/3/2026

1. NORMA DE GESTIÓN DE IDENTIDADES Y ACCESOS (SI)

El Banco PYME Ther S.A. fundamenta su control de accesos en el principio de mínimo privilegio, asegurando que cada usuario disponga únicamente de los permisos necesarios para el cumplimiento de sus funciones. La administración centralizada de identidades recae en la Subgerencia de Operaciones y Soporte, a través del Encargado de Gestión de Accesos, mientras que la Gerencia de Seguridad de la Información establece los lineamientos y controles de supervisión.

Todos los usuarios, tanto administrativos como operativos en agencias, cuentan con perfiles definidos en base a roles alineados al Manual de Funciones. Para el acceso a sistemas críticos, como el Core Bancario, servidores o infraestructura de almacenamiento, así como para conexiones remotas mediante VPN, es obligatorio el uso de autenticación multifactor conforme a las políticas del SGSI.

La Gerencia de Seguridad de la Información realiza revisiones semestrales de la Matriz de Accesos con el fin de identificar posibles excesos de privilegios o anomalías, reportando sus resultados directamente al Directorio. Asimismo, se exige que todas las credenciales cumplan con criterios de complejidad y renovación periódica, quedando estrictamente prohibido el uso de cuentas compartidas o credenciales de terceros. En el caso del personal desvinculado, las credenciales son revocadas en tiempo real mediante mecanismos automatizados integrados con el sistema de Recursos Humanos, proceso que es auditado mensualmente por el área de Seguridad. Adicionalmente, los accesos remotos son monitoreados mediante el análisis de logs, los cuales se

conservan por un periodo mínimo de doce meses para fines de auditoría y control.

2. NORMA DE DESARROLLO SEGURO DE SOFTWARE (SI)

El Banco PYME Ther S.A. incorpora la seguridad como un componente esencial en todo el ciclo de vida del desarrollo de software, abarcando sus plataformas de banca web, aplicaciones móviles y APIs del Core Bancario. La Gerencia de Seguridad de la Información define los controles que deben aplicarse en cada fase, en coordinación con la Subgerencia de Aseguramiento de Calidad. Antes de su paso a producción, toda aplicación debe someterse a evaluaciones de seguridad tanto estáticas como dinámicas, con el objetivo de identificar vulnerabilidades en el código y en su comportamiento en ejecución, siguiendo las buenas prácticas establecidas por OWASP Top 10. La aprobación final de estos controles es responsabilidad exclusiva de la Gerencia de Seguridad, garantizando independencia respecto al área de QA.

El uso de componentes de terceros se encuentra sujeto a evaluaciones de riesgo, exigiendo su actualización permanente y prohibiendo la incorporación de librerías con vulnerabilidades conocidas sin un plan de mitigación formalmente aprobado. Asimismo, se mantiene una estricta segregación de ambientes, impidiendo que los desarrolladores tengan acceso al entorno de producción. De manera complementaria, se realizan pruebas de penetración periódicas sobre los canales digitales, con el fin de validar la resistencia de los sistemas ante posibles ataques. Cualquier incidente o vulnerabilidad detectada durante el ciclo de desarrollo es reportada formalmente a la Gerencia de Seguridad para su registro y tratamiento dentro del SGSI.

3. NORMA DE CONTINUIDAD Y RESILIENCIA DE SEGURIDAD

El Banco PYME Ther S.A. asegura la continuidad de sus operaciones mediante la protección de la información crítica y la implementación de planes de recuperación ante desastres. La Gerencia de Seguridad de la Información supervisa tanto la integridad como la confidencialidad de los respaldos, así como la efectividad del Plan de Recuperación ante Desastres. Todos los respaldos de información deben mantenerse cifrados utilizando estándares robustos, garantizando su protección frente a accesos no autorizados. De forma trimestral, la Gerencia de Seguridad verifica su integridad mediante controles criptográficos. Asimismo, se ejecutan simulacros semestrales de recuperación, con el objetivo de validar el cumplimiento de los tiempos de recuperación (RTO) y puntos de recuperación (RPO) definidos en la planificación estratégica.

Los sistemas críticos del banco cuentan con objetivos de recuperación progresivamente exigentes, asegurando la restauración de los servicios dentro de los plazos establecidos. Los medios de respaldo fuera de sitio son almacenados en ubicaciones físicamente seguras, con controles de acceso debidamente documentados y auditados. El Plan de Recuperación es revisado y actualizado al menos una vez al año, o cuando se producen cambios significativos en la infraestructura tecnológica o en el entorno de amenazas, garantizando su vigencia y efectividad.

4. NORMA DE SEGURIDAD FÍSICA Y PERIMETRAL (SI)

El Banco PYME Ther S.A. establece controles de seguridad física y perimetral orientados a proteger sus activos críticos, especialmente el Centro de Procesamiento de Datos (CPD) y las áreas consideradas de acceso restringido.

La Gerencia de Seguridad de la Información define estos lineamientos en coordinación con el responsable de Seguridad Física, asegurando su correcta implementación y supervisión. El acceso a instalaciones críticas, como el CPD y las salas de telecomunicaciones, se encuentra limitado exclusivamente al personal autorizado, mediante mecanismos de autenticación como controles biométricos o tarjetas de acceso. Dichos accesos se gestionan a través de una Matriz de Acceso Físico, la cual es revisada y actualizada de forma semestral.

Las instalaciones cuentan con sistemas de monitoreo continuo, incluyendo videovigilancia (CCTV), detección de intrusiones y mecanismos de protección ante eventos ambientales como incendios o inundaciones. En paralelo, la seguridad perimetral lógica se basa en el uso de tecnologías como firewalls de nueva generación y sistemas de protección de aplicaciones, bajo un enfoque restrictivo de “denegar todo por defecto”. Cualquier incidente o brecha de seguridad física es reportado de inmediato a la Gerencia de Seguridad de la Información para su gestión formal. Asimismo, la red institucional se mantiene segmentada conforme a estándares internacionales, con el objetivo de proteger entornos sensibles como los relacionados con datos de tarjetas.

5. NORMA DE CLASIFICACIÓN Y PRIVACIDAD DE DATOS

El Banco PYME Ther S.A. gestiona su información bajo un enfoque de clasificación que permite establecer niveles adecuados de protección según la sensibilidad de los datos. La Gerencia de Seguridad de la Información, en coordinación con la Unidad de Administración de Datos, define los criterios de clasificación, manejo y resguardo de la información institucional. Toda la información es categorizada en niveles que incluyen datos confidenciales o críticos, de uso interno y de carácter público, aplicándose controles

diferenciados para su almacenamiento, transmisión y eliminación. La información financiera, los datos personales de clientes y los datos asociados a tarjetas son considerados de máxima criticidad y deben permanecer cifrados tanto en tránsito como en reposo. El intercambio de información sensible con terceros requiere la formalización de acuerdos de confidencialidad debidamente aprobados, asegurando el cumplimiento de las políticas internas y los marcos regulatorios. Para fines analíticos y regulatorios, las consultas se realizan exclusivamente sobre entornos controlados, evitando el acceso directo a bases de datos de producción. La eliminación de información confidencial se ejecuta mediante mecanismos seguros, que incluyen destrucción certificada para medios físicos y borrado criptográfico para medios digitales. Asimismo, cualquier tratamiento de datos personales en entornos externos o en la nube se rige por estándares internacionales de protección de privacidad.

6. NORMA DE MONITOREO, AUDITORÍA Y RESPUESTA A INCIDENTES

El Banco PYME Ther S.A. mantiene un esquema de monitoreo continuo de sus activos tecnológicos, garantizando una detección oportuna de eventos de seguridad y una respuesta estructurada ante incidentes. La Gerencia de Seguridad de la Información ejerce esta función de manera independiente, asegurando objetividad en la supervisión y control. Las estaciones de trabajo y servidores cuentan con herramientas de detección y respuesta ante amenazas (EDR), las cuales alimentan sistemas centralizados de correlación de eventos. Los registros de auditoría generados por sistemas críticos son protegidos contra alteración o eliminación, siendo su custodia responsabilidad directa del área de Seguridad, con un periodo de retención mínimo de doce meses.

Ante la ocurrencia de incidentes, se sigue un proceso formal que abarca las etapas de detección, contención, erradicación y recuperación. Los incidentes críticos son escalados a niveles superiores de gestión e incluso a entidades regulatorias cuando corresponde. La meta institucional es lograr tiempos de contención cada vez más eficientes, en línea con los objetivos estratégicos del banco. Adicionalmente, se realizan pruebas periódicas de seguridad, como evaluaciones de penetración, cuyos resultados son gestionados de forma confidencial. Todos los incidentes son registrados y analizados con el fin de identificar oportunidades de mejora, fortaleciendo continuamente el Sistema de Gestión de Seguridad de la Información. La Gerencia de Seguridad reporta directamente al Directorio, garantizando su independencia respecto a otras áreas de TI.

7. MARCOS Y ESTÁNDARES DE SEGURIDAD APLICADOS

- La norma ISO/IEC 27001 constituye el marco principal para la gestión integral de riesgos de seguridad de la información, estableciendo las bases para la implementación de controles y la mejora continua. En complemento, ISO/IEC 27018 orienta la protección de datos personales, especialmente en entornos cloud y en la relación con proveedores externos.
- El marco NIST CSF 2.0 proporciona una estructura funcional para la ciberseguridad, organizando las capacidades del banco en torno a los procesos de identificar, proteger, detectar, responder y recuperar. Por su parte, los CIS Controls v8 establecen controles técnicos prioritarios aplicados a la protección de endpoints, redes y accesos.

- En el ámbito del desarrollo de software, se adoptan las buenas prácticas definidas por OWASP Top 10, mientras que el estándar PCI DSS v4.0 regula estrictamente la protección de los datos de tarjetas, incluyendo requisitos de segmentación de red y cifrado.
- El marco COBIT 2019 permite alinear la gestión de tecnologías de la información con los objetivos estratégicos del banco, bajo la supervisión del Directorio. Todo este conjunto de estándares se integra con la normativa emitida por la ASFI, garantizando el cumplimiento de las disposiciones regulatorias vigentes en Bolivia.